

Roles, Pages & Access — دليل الأدوار والصلاحيات

A plain-language reference for IT: **who each role is, which pages they see, what they can do, and what the server lets them touch.** The authoritative sources in code are `prisma/seed.ts` (permission matrix), `lib/security/rbac.ts` (enforcement) and `lib/viewModel.ts` (page/menu scoping).

1. How access works (two layers)

- 1. **UI role** (`users.role` , one of `coord` / `path` / `deputy` / `ai` / `admin`) — decides which **screens, menus, cards and buttons** the user sees.
- 2. **Backend RBAC** (`user_roles` → `role_permissions` + entity/stream scopes) — every API call re-checks: valid session → permission code → entity/stream scope → action, and writes an `audit_logs` row. Hiding a button is UX only; the server check is what actually protects the data.

On first login the identity (UAE PASS / Workspace ONE / mock-dev) is mapped to a `users` row; the UI role and backend role are assigned from `role_assignment_rules` or the admin APIs. **All accounts for all entities are provisioned centrally by the system admin** — there is no self-service team setup.

2. Quick reference

UI role	Arabic	Backend code	Data scope	One-line job
<code>coord</code>	منسق المسار في الجهة	<code>entity_coordinator</code>	own entity + own stream(s) (incl. drafts)	Fills the stream inventory and distributes entries over دفعات الإطلاق
<code>path</code>	رئيس المسار	<code>stream_owner</code>	own stream , all entities	The ent1 approver — اعتماد / إعادة للتعديل / طلب تفاصيل
<code>deputy</code>	نائب رئيس المسار	<code>stream_owner</code>	own stream , all entities	Same review powers as the stream head
<code>ai</code>	اللجنة الوطنية (الرئيس + الأمانة العامة)	<code>ai_committee</code>	everything , approved entries only	National read-only oversight
<code>admin</code>	مشرف النظام	<code>system_admin</code>	global	Manages users, roles, the public site and inquiries

Legacy backend roles (`entity_representative` , `entity_admin`) remain seeded for compatibility but are **not part of the current flow** and hold no approval permissions.

الخدمات الحكومية · (strategy) العمل الحكومي الاستراتيجي · (ops) العمليات والدعم المؤسسي (3) Streams (services).

Entry types (one per stream, enforced everywhere): عملية in ops · مهمة in strategy · خدمة in services .
Statuses are exactly four: معتمد / قيد الاعتماد / للتعديل / معتمد (approved entries are locked).

3. Role by role

3.1 منسق المسار في الجهة — coord / entity_coordinator

Who: the working-level user inside a federal entity, responsible for one stream — or several: with more than one user_stream_scopes row, the sidebar's **قوائم الحصر** lists every assigned stream.

Pages (sidebar): - **قوائم الحصر** — one entry per assigned stream; each opens the stream's inventory table with the stream's own columns and filters (ops: **نوع عملية الدعم المؤسسي** / **القطاع** / **تصنيف العملية** / **الحالة** (conditional) — strategy: **الأولوية** / **المحور** — services: **الخدمة** / **الأولوية** — plus **دفعات الإطلاق** everywhere) — one sub-page per assigned stream: the stream's batches (الدفعة الأولى... السادسة) with «إضافة مدخل» per batch, start/end dates bounded to the **دفعة** window - **إرشادات استخدام المنصة** — the guided tour

Can do: add entries manually («إضافة يدوية») — in the services stream **الخدمة الفرعية** / **الخدمة** come from the entity-scoped **دليل الخدمات** dropdowns) or via the per-stream Excel template («رفع ملف Excel») — incomplete rows import as «بيانات ناقصة» drafts); select drafts → «إرسال للاعتماد» / «إكمال وإرسال» (with the missing-fields popup); distribute entries over **دفعات** and set their dates; export reports.

Cannot: approve or reject; edit an approved (معتمد) entry; place an entry on another stream's batches; see other entities.

3.2 رئيس المسار ونائبه — path + deputy / stream_owner

Who: the national head (and deputy) of ONE stream, seeing that stream across **all** entities. Assigned by the system admin with the stream scope.

Pages (sidebar): - **دفعات** - **الجهة** / **الأولوية** / **الحالة** — **قائمة حصر المسار** — all entities' entries of the stream with **الجهات** — the stream's batches (read-only; distribution and dates are the coordinator's responsibility) — **المشاركة** — participation per entity

Can do: entries **قيد الاعتماد** / **اعتماد** / **إعادة للتعديل** / **طلب تفاصيل إضافية** — from the list row, the details drawer, or the notification. Every decision notifies the coordinator. Export.

Cannot: create or edit entries; return an entry after it is **معتمد**.

3.3 الرئيس + الأمانة العامة — ai / ai_committee

Who: national oversight over the approved portfolio.

Pages (sidebar): - **الرئيسية** — national KPI boxes (**غير قابلة**) **إجمالي المدخلات**, **القابلة للتحويل**, **المستهدف تحويلها**, **غير قابلة** — **توزيع المدخلات حسب دفعات الإطلاق** - **قوائم الحصر** (للتحويل) and the three stream cards, each with **قوائم الحصر**

5. Backend permission matrix (seeded — `prisma/seed.ts`)

Permission	coord	stream head/deputy	committee	admin
items:view / export	✓	✓	✓	✓
items:create / update / submit	✓	—	—	✓
items:approve / reject	—	✓ (the ent1 gate)	✓ ¹	✓
reports:view	✓	✓	✓	✓
reports:export	—	—	✓	✓
ai_review:run	—	—	✓	✓
users / roles / audit / settings	—	—	—	✓

¹ Committee approval permissions exist for future gates; in the current flow the committee is read-only and the ent1 approval is performed by the stream head or deputy.

Extra backend-only roles (no dedicated UI — they land on the closest read-only view): `program_admin` (مدير البرنامج) — everything except `settings:*` · `viewer` (مستعرض) — read-only within scopes · `auditor` (مدقق) — read-only + `audit:view` · `entity_representative` / `entity_admin` — legacy, view-level only.

6. Where this is enforced in code

Concern	File
Permission + scope checks per request	<code>lib/security/rbac.ts</code> (<code>assertPermission</code> , <code>assertItemAccess</code>)
Session → user + roles + scopes	<code>lib/security/auth.ts</code> , <code>/api/auth/me</code>
Role/permission/scope tables	<code>prisma/schema.prisma</code> (migrations <code>0007</code> – <code>0010</code>)
Seeded matrix + starter accounts	<code>prisma/seed.ts</code>
Entity-scoped services catalog	<code>app/api/svc-catalog/route.ts</code> , <code>lib/svcCatalog.ts</code>
Page/menu/filter scoping (UX)	<code>lib/viewModel.ts</code>
Identity → user mapping on login	<code>lib/security/user-access.ts</code>